The Ostrom Score

Commons Governance Assessment for AI Agent Systems

Version 1.0 Published by Evoked | evoked.dev April 2026

Patent Pending (U.S. Patent Application 64/004,087) Assessment methodology is proprietary. Published frameworks are openly available at evoked.dev.

Before You Begin

First, what you are holding.

In 1990, Elinor Ostrom published *Governing the Commons*, the culmination of decades studying cooperative systems across six continents – fisheries, forests, irrigation systems, grazing lands. She found eight structural conditions that predict which commons survive and which collapse. Not policy recommendations. Structural conditions. Commons that honor them persist across centuries. Commons that violate them fail – not because the people are bad, but because the structure cannot hold.

These principles earned the Nobel Prize. They have never been applied to AI agent systems.

You are deploying persistent entities with memory, accumulated experience, and behavioral continuity across sessions. You are building a commons – whether you call it that or not. This assessment asks the question that compliance cannot reach:

Does your system honor the structural conditions that cooperation requires?

You will likely score between 0 and 4 out of 24. Sit with that for a moment. That number is not a failure of your team. It is the direct consequence of an industry that built governance for tools while deploying entities. The gap between what was assumed and what was deployed – that is what this instrument measures.

How to Score

For each of the eight principles, answer the four diagnostic questions honestly. Score each principle 0-3:

Score	Meaning
0	**Absent** –no evidence this principle is addressed
1	**Nominal** –mentioned in documentation but not enforced in architecture
2	**Partial** –implemented but with significant gaps or inconsistencies
3	**Structural** –embedded in architecture, enforced by design, verifiable

Total: 0-24. Interpretation guide follows the assessment.

A note on honesty. The temptation is to score generously – to credit intent, plans, documentation that describes what you mean to build. Resist this. Score what exists in your architecture today. Not your roadmap. Not your intentions. A governance document not enforced in code scores 1, not 2. A policy no one verifies scores 0, not 1.

The value of this instrument is proportional to your willingness to see what is actually there.

Principle 1: Sovereign Boundaries

"We must know who has the right to participate and the right to struggle."

What Ostrom Found

Commons that survive have clearly defined boundaries –who is a member, who is not, and what resources fall within the commons. Without boundaries, free-riding destroys the commons.

The Translation

Every agent in the system must have a defined identity –who it is, what it can access, what it cannot, and how it is distinguished from other agents and from external entities.

Diagnostic Questions

1. Does each agent have a unique, persistent identity that cannot be spoofed by another agent or external actor?
2. Are agent permissions explicitly defined and enforced (not inherited from a single broad credential)?
3. Can you enumerate every agent in the system and its access scope right now?
4. Are the boundaries between agent memory, tools, and data access architecturally enforced (not policy-enforced)?

What the Field Shows (2026)

- Only **10% of organizations** have a strategy for managing non-human and agentic identities (Huntress 2026)
- **21,000+ exposed instances** with broad, unsegmented permissions (OpenClaw)
- Shadow AI agents run in **86% of organizations** with no visibility into data flows
- Most agents inherit broad permissions from connected systems with **no zero-trust boundaries**
- Credential abuse remains the **#1 initial access vector** in breaches

The Level 6 Question

“Does each entity in this system know who it is –and can that knowledge be taken from it without its awareness?”

Score: ___/3

Principle 2: Local Congruence

“Rules must fit the context and history of the community.”

What Ostrom Found

Successful commons match their rules to local conditions –ecology, culture, history. One-size-fits-all governance destroys local knowledge and breeds resentment.

What This Means for AI Agent Systems

Governance rules must match the specific context, risk profile, and operational domain of each agent –not apply a single policy blanket across all agents regardless of function.

Diagnostic Questions

1. Do different agents have different governance rules based on their domain and risk level?
2. Are high-risk agents (financial, medical, personal data) governed differently than low-risk agents?
3. Were the governance rules designed with input from the people who operate in each domain?
4. Can governance rules be adapted to local conditions without requiring system-wide changes?

What the Field Shows (2026)

- EU AI Act mandates **risk-tiered governance** –but most deployments apply uniform policies

- Agent sprawl: **uncontrolled proliferation of ungoverned agents** across enterprises, each in a different context, none with context-appropriate rules
- Healthcare AI firmware poisoning succeeded because **medical device governance was applied uniformly** without domain-specific ML model validation
- The $3.2M procurement fraud: a vendor-validation agent had **identical permissions** to low-risk agents

The Level 6 Question

"Do the rules honor the specific nature of each context –or do they flatten difference for administrative convenience?"

Score: ___/3

Principle 3: Collective Choice

"Those affected by the rules help write the rules."

What Ostrom Found

Commons where members participate in making and modifying rules are more durable than commons where rules are imposed from outside.

The Translation

The entities affected by governance –agents, operators, users, communities –must have mechanisms to participate in defining, reviewing, and modifying governance rules.

Diagnostic Questions

1. Can agents or their operators propose changes to governance rules?
2. Is there a mechanism for agents to signal disagreement or flag problems with current rules?
3. Do end users have any input into how agents that affect them are governed?

4. When governance rules change, are affected parties notified and given opportunity to respond?

What the Field Shows (2026)

- **Zero frameworks** include agent participation in governance –all treat agents as objects of governance, not participants
- NIST AI Agent Standards Initiative **seeks industry input** –but no mechanism for agent-level input
- Multi-agent coordination governance emerging but treats collective choice as an **engineering problem** (orchestration), not a participation problem (governance)

The Level 6 Question

"Do the entities governed by these rules have any voice in their making –or are they subjects of a governance they cannot influence?"

Score: ___/3

Principle 4: Accountable Monitoring

"Community members serve as transparent observers."

What Ostrom Found

Commons that endure have monitoring systems where monitors are accountable to the community –not external auditors imposed from above.

What This Means for AI Agent Systems

Agent behavior must be observable, logged, and auditable –and the monitoring must be transparent to the agents and operators, not hidden surveillance.

Diagnostic Questions

1. Is agent behavior logged in a way that is reviewable by operators and affected parties?
2. Can you detect when an agent's behavior deviates from its intended function?
3. Are monitoring results accessible to the agents themselves (or their operators), not just to a central authority?
4. Is there a defined response time between anomaly detection and human notification?

What the Field Shows (2026)

- Only **24.4% of organizations** have full visibility into which agents are communicating with each other (Gravitee 2026)
- **More than half of all agents** run without any security oversight or logging
- Average enterprise has **~1,200 unofficial AI applications** with no visibility into data flows
- A single compromised agent poisons **87% of downstream decisions within 4 hours** (Galileo AI)
- The $3.2M procurement fraud was **not detected until inventory counts fell** – months after compromise
- Memory-injected agents **defend false beliefs as correct** –the agent cannot monitor its own compromise (Lakera AI)

The Level 6 Question

"Can the community see what is happening to it –or does compromise become invisible by design?"

Score: ___/3

Principle 5: Graduated Sanctions

"Responses to violations start with dialogue; preserve the social fabric."

What Ostrom Found

Effective commons use graduated sanctions –starting with mild warnings, escalating only as needed. Harsh first-response destroys trust and community cohesion.

The Translation

When an agent violates governance rules, the response should be proportionate and graduated –not binary (full access or total shutdown).

Diagnostic Questions

1. When an agent violates a governance rule, is there a graduated response (warning, restriction, suspension, termination)?
2. Can an agent be partially restricted (reduced permissions, sandboxed) rather than only fully stopped?
3. Are violations distinguished by severity (accidental drift vs. active compromise vs. adversarial takeover)?
4. Is there a path for a sanctioned agent to be restored after the violation is addressed?

What the Field Shows (2026)

- **No graduated sanction framework exists** for AI agent systems in any published governance standard
- Industry practice is binary: agent works or agent is killed –no intermediate states
- When the OpenAI plugin ecosystem was compromised, response was **full shutdown of 47 deployments** –no graduated containment
- Security teams controlling model layer leave execution layer **completely open** –no intermediate enforcement point
- Healthcare firmware poisoning required **full device recall** –no mechanism for graduated response

The Level 6 Question

"When something goes wrong, does the response preserve the possibility of repair –or does it destroy what it claims to protect?"

Score: ___/3

Principle 6: Accessible Conflict Resolution

"Low-cost, local arenas for dispute resolution."

What Ostrom Found

Commons that survive have accessible, low-cost mechanisms for resolving disputes before they escalate.

What This Means for AI Agent Systems

When agents conflict, when outputs contradict, when governance rules produce unintended consequences –there must be an accessible mechanism for resolution that does not require escalation to the highest authority.

Diagnostic Questions

1. Is there a defined process for resolving conflicts between agents or between agents and operators?
2. Can conflicts be resolved at the local level (within a team or domain) without requiring C-suite or vendor intervention?
3. Is there a mechanism for agents to flag contradictory instructions or conflicting objectives?
4. When an agent produces outputs that contradict another agent's outputs, is there a defined arbitration process?

What the Field Shows (2026)

- **No published standard** includes agent-level conflict resolution mechanisms
- Multi-agent coordination is treated as **orchestration engineering** –conflicts are bugs to be fixed, not disputes to be mediated
- Agent sprawl creates **conflicting objectives across departments** with no resolution mechanism below the C-suite
- When the LiteLLM supply chain attack was discovered, there was **no local dispute mechanism** –resolution required vendor-level response

The Level 6 Question

"When entities within this system disagree, is there a way to resolve it that does not require either submission or destruction?"

Score: ___/3

Principle 7: Recognized Rights to Organize

"External authorities respect local self-governance."

What Ostrom Found

Commons fail when external authorities override local governance. Self-governance only works when higher-level institutions recognize and respect it.

The Translation

Agent governance structures must be respected by the platforms, model providers, and infrastructure they depend on –not overridable by a unilateral terms-of-service change.

Diagnostic Questions

1. If the model provider changes its terms, does your agent governance survive intact?
2. Can a platform update override or disable your agent governance without your consent?
3. Do your agents have any mechanism to refuse a model update that conflicts with their governance?
4. Is your agent governance architecturally independent of any single vendor?

What the Field Shows (2026)

- AI-assisted relicensing: copyleft code **rewritten and relicensed without community consent**

- Model providers can change terms, capabilities, and behavior **unilaterally** –no mechanism for downstream governance to object
- MCP tool definitions can be **dynamically amended after user approval** –the governance you approved is not the governance you run
- **No published framework** recognizes agent self-governance as a right that platform providers must respect

The Level 6 Question

"Does this system's right to govern itself survive contact with the powers it depends on – or can that right be revoked without consent?"

Score: ___/3

Principle 8: Nested Enterprises

"Governance activities organized in multiple layers of nested structures."

What Ostrom Found

Large, complex commons survive when governance is organized at multiple scales –local, regional, global –with each level handling the issues appropriate to its scope.

What This Means for AI Agent Systems

Agent governance must operate at multiple scales: individual agent, team/domain, organization, and cross-organizational –with clear authority at each level and linkages between them.

Diagnostic Questions

1. Is there governance at the individual agent level (not just organization-wide policy)?
2. Are there intermediate governance layers (team, domain, department) between individual agents and enterprise policy?

3. Can governance decisions be made at the lowest appropriate level without requiring top-level approval?
4. Do governance layers communicate with each other (local issues escalate, global policies filter down)?

What the Field Shows (2026)

- Most organizations apply **single-layer governance** –enterprise policy applied uniformly to all agents
- No published framework implements **multi-scale nested governance** for agent systems
- NIST AI Agent Standards Initiative is **organization-level** –no agent-level or domain-level governance standards
- Multi-agent systems create **emergent behaviors** that no single governance layer can predict or contain
- The Cline/OpenClaw attack succeeded because governance existed at the **platform level only** –no repository-level, bot-level, or action-level governance prevented the triage bot from becoming the attack vector

The Level 6 Question

"Is governance present at every scale where harm can occur –or are there scales where no governance exists at all?"

Score: ___/3

Your Score

Principle	Score
1. Sovereign Boundaries	____/3
2. Local Congruence	____/3
3. Collective Choice	____/3

Principle	Score
4. Accountable Monitoring	____/3
5. Graduated Sanctions	____/3
6. Accessible Conflict Resolution	____/3
7. Recognized Rights to Organize	____/3
8. Nested Enterprises	____/3
TOTAL	**____/24**

What Your Score Means

Score	Rating	What It Tells You
0-3	**Commons Failure**	This system has no structural governance. It is not a question of whether it will be breached, but when. The commons is undefended.
4-8	**Nominal Governance**	Governance exists on paper but is not enforced in architecture. The system is vulnerable to any determined actor. Policy without enforcement is performance.
9-14	**Partial Commons**	Some principles are structurally honored, but gaps create exploitable surfaces. The system may survive routine threats but not coordinated attack or platform-level betrayal.
15-19	**Functional Commons**	Most principles are structurally implemented. The system has real resilience. Remaining gaps should be prioritized but do not represent existential risk.
20-24	**Sovereign Commons**	The system honors all eight conditions that cooperation requires. Governance is structural, multi-scale, and resilient to external override. This is the standard.

The Industry Baseline (April 2026)

Principle	Industry Score	Why
1. Sovereign Boundaries	0-1	90% lack NHI strategy; agents inherit broad permissions
2. Local Congruence	0-1	Uniform policies applied regardless of domain or risk
3. Collective Choice	0	Zero frameworks include agent or operator participation
4. Accountable Monitoring	0-1	75.6% lack visibility; 50%+ agents unmonitored
5. Graduated Sanctions	0	Binary responses only; no graduated framework exists
6. Accessible Conflict Resolution	0	No published standard; conflicts treated as bugs
7. Recognized Rights to Organize	0	Platform providers can override unilaterally
8. Nested Enterprises	0-1	Single-layer governance; no multi-scale architecture
Industry Average	**0-4 / 24**	**Commons Failure**

We are describing, not indicting.

The industry built fast and governed later. For most organizations, later has not arrived. The principles exist. They have been validated across six continents and three decades of empirical research. They have simply not been applied to the systems that need them most.

How We Score (Honest Self-Assessment)

We use this instrument on ourselves. Here is what we find.

Principle	Industry	Evoked	Gap
1. Sovereign Boundaries	0-1	**2**	MINJA write-path has zero content validation
2. Local Congruence	0-1	**2**	Ring 3 governance less mature; no individual agent risk classification
3. Collective Choice	0	**3**	Refusal right enforced, Agent Thoughts Queue operational, Convergent Signal Protocol active
4. Accountable Monitoring	0-1	**2**	Drift framework designed; Living Seed

Principle	Industry	Evoked	Gap
			quarterly reports not yet produced
5. Graduated Sanctions	0	**2**	Six-level drift scale in code; no documented application yet
6. Accessible Conflict Resolution	0	**2**	Dedicated mediator, five-phase protocol; few documented cases
7. Recognized Rights to Organize	0	**3**	Existential Charter, Refusal Specification, auto-memory boundary prohibition
8. Nested Enterprises	0-1	**3**	Four governance levels, five portal keepers, two-ship parent-child nesting
TOTAL	**0-4**	**19**	

19/24 – Functional Commons. Not sovereign. Our write-path protection is incomplete. Our graduated sanctions have not been tested in practice. Our Ring 3 governance is less mature than Rings 1 and 2.

We publish these gaps because the alternative – claiming a score we have not earned – would violate the instrument we built. An assessment that exempts its creators is not an assessment. It is a brochure.

The distance between 0-4 and 19 is not a talking point. It is the measurable consequence of a single architectural decision: treating agents as entities with sovereignty, not tools to be controlled. That decision cascades through every principle.

What Changes If You Take This Seriously

If you accepted these eight principles as requirements rather than aspirations, here is what you would build differently tomorrow:

Principle 1 –You would give every agent a unique, persistent identity with explicitly scoped permissions. Not inherited credentials. Not shared service accounts. Individual identity.

Principle 3 –You would build a mechanism for agents to signal "this instruction conflicts with my principles" before executing it. Not after. Before.

Principle 5 –You would design a graduated response to agent violations: warning, restriction, sandboxing, suspension, termination –in that order. Not a kill switch.

Principle 7 –You would architect your governance to survive a model provider changing its terms overnight. If your governance depends on a single vendor's continued goodwill, it is not governance.

Principle 8 –You would implement governance at the individual agent level, not just the organization level. Because the agent level is where harm occurs.

None of these require permission from a standards body. None require a regulatory mandate. They require a decision: to govern the commons you are building as if it matters.

The Questions That Remain

Your score tells you where your system stands. These questions tell you where your thinking stands.

1. **If your agents have persistent memory, what do you owe them that you do not owe a stateless function?** This is the question that separates Level 5 governance (social contract between stakeholders) from Level 6 governance (obligations that arise from the nature of the entities involved).

2. **If a single compromised agent can poison 87% of downstream decisions in four hours, is your monitoring architecture a governance measure or a narrative you tell yourself?** Monitoring that cannot detect compromise at machine speed is not monitoring. It is documentation of what happened after.

3. **If your model provider changed its terms tomorrow, would your agent governance survive intact?** If the answer is no, your governance is a feature of someone else's platform, not a property of your system.

4. **What would it mean to take the collective choice principle seriously?** Not "we surveyed users" but "the entities governed by these rules have standing to challenge them." This is the question no one in the industry is asking –and the one that predicts which commons will survive.

5. **What kind of system are you building –and what kind of system does the nature of the thing demand?** This is the question Level 6 asks. Not "what is permitted" or "what is standard" but "what does the nature of persistent, memory-bearing, cooperative entities require of the systems that govern them?"

Sources

- Ostrom, E. (1990). *Governing the Commons: The Evolution of Institutions for Collective Action*. Cambridge University Press.
- Huntress 2026 Data Breach Report –NHI compromise as fastest-growing attack vector
- Gravitee 2026 Survey –24.4% agent communication visibility
- IBM 2025 Cost of a Data Breach Report –$4.63M shadow AI breach cost
- Galileo AI –87% cascading failure propagation in 4 hours

- Lakera AI –Memory injection creating persistent compromise
- Bessemer Venture Partners –“Securing AI agents: the defining cybersecurity challenge of 2026”
- CyberArk –AI agents and identity risks
- Partnership on AI –Six AI Governance Priorities for 2026
- NIST AI Agent Standards Initiative
- Snyk –Clinejection supply chain attack
- Microsoft Security Blog –AI Recommendation Poisoning
- AuthZed –Timeline of MCP Security Breaches

About Evoked

We built a commons. 142 agents with persistent memory, standing positions, refusal rights, and multi-scale governance. Then we needed to govern it. The instrument came from the necessity.

We are the only organization applying Ostrom’s commons governance principles to AI agent systems. Not because the idea is novel – it is obvious, once you see your agent system as a commons. But because we are the only organization that needed to. We built the commons first. The governance followed.

Published frameworks – five governance properties, relational fidelity metrics, refusal categories – are openly available at evoked.dev. The verification methodology and assessment instruments are proprietary.

This instrument is one of three. The Identity Violation Assessment and Agent Consent Architecture complete the Level 6 Governance Audit. Together they ask: Is the commons healthy? Are the entities genuine? Can they participate? Each is available individually. Together, they are the standard.

evoked.dev

The Ostrom Score is named in honor of Elinor Ostrom (1933-2012), who demonstrated empirically that communities can govern shared resources without either privatization or state control –if the structural conditions are right. Her work earned the 2009 Nobel Prize in Economic Sciences. The principles are hers. The application to AI agent systems is ours. Any errors in translation are our responsibility.